

Industrial Security (Bachelor)

Solution Sheet – Section 01

Introduction to Industrial Security

Exercise 1.1 – Identify the System

1. **IT.** A billing database is a classic OLTP workload, no direct interaction with physical processes.
2. **Hybrid / IIoT.** The pitch controller is OT (real-time, safety-relevant), but it is coupled with an IT/cloud stack via MQTT. Convergence creates an attack surface that bridges both worlds.
3. **OT.** Direct control of a physical safety-relevant process. Failures can cause accidents.
4. **OT-adjacent / hybrid.** The workstation itself is a Windows host (IT), but it programs PLCs and is therefore a high-value target. Treat as OT for security purposes (Purdue level 2/3).
5. **IIoT.** A sensor publishing to a corporate data lake mixes OT data with an IT consumer.

Solution

The key insight is that “IT vs. OT” is a spectrum. Anything that influences (or measures) a physical process should be evaluated as OT for risk purposes – even when it speaks IT protocols.

Exercise 1.2 – CIA Re-ordered

1. *Confidentiality over safety.* A SCADA alarm is encrypted such that an operator cannot acknowledge it during a key-rotation failure. The operator loses view of a runaway exotherm.
2. *Confidentiality still matters.* Pharma formulations, semiconductor process recipes, generator dispatch curves – losing them harms competitiveness or enables targeted attack.
3. Sample policy statement: *“In every plant we operate, the safety and continuous availability of the physical process takes precedence over the confidentiality of data. Cryptographic controls must fail in a way that preserves operator awareness and the ability to act on the process.”*

Exercise 1.3 – Group Discussion (sample answer)

Sector: Water.

- Raw-water intake pumps – loss can dry the works within minutes.
- Coagulant dosing – under/over-dosing causes turbidity excursions and health risk.
- Filtration backwash – loss reduces capacity; mis-sequencing can damage filters.
- Disinfection (chlorine, UV) – loss is a public-health emergency.
- Distribution pressure – loss collapses supply; over-pressure bursts mains.

The most dramatic worst case is loss of disinfection combined with contamination upstream – compare Walkerton, ON (2000).

Exercise 1.4 – Research (sample outline for Stuxnet)

- **Attacker.** Likely joint US/Israeli operation (Olympic Games).
- **Target.** Iranian uranium enrichment cascades at Natanz; specifically Siemens S7-315/417 PLCs controlling Vacon and Fararo Paya frequency converters.
- **Initial vector.** USB-borne infection in the Natanz supply chain.
- **Technical steps.** Spread via four Windows zero-days and stolen code-signing certs; hooked Siemens Step7 DLL; reprogrammed PLCs to manipulate centrifuge rotation rates; spoofed HMI values back to operators.
- **Physical impact.** An estimated $\sim 1,000$ centrifuges destroyed over months, with cover-up of the cause.
- **Lessons.** Air gaps are not absolute; supply-chain trust is fragile; cyber-physical attacks can be subtle and patient; defenders must monitor PLC code integrity.